Actividad N°2 – Del caso a los primeros riesgos
Caso elegido: Caso 1 – Plataforma de comercio electrónico: NortiShop - Tabla por Campo Sensible

Integrantes:

Catalina Toledo
María Gerónimo
Pablo Lineros

Actor	Dato que maneja	Campo	Necesidad	Elección	Criterio Tecnico	Implementación	Evidencia
Cliente registrado	Nombre y datos de la cuenta	nombre, email, telefono	El usuario autorizado y el sistema deben recuperar los datos del perfil para su gestión y mostrar la cuenta.	Cifrado simétrico en reposo (AES-256) + TLS en tránsito	Se necesita reversibilidad para consultar la información del perfil y proteger los datos personales (PII).	Usar una librería criptográfica del lenguaje (ej. AES-256) resguardando la llave secreta en variables de entorno / Secrets Manager.	Código de cifrado/descifrado, datos cifrados en BD y comprobación de recuperación en la vista de perfil.
Cliente registrado	Contraseña	password_hash	El sistema requiere autenticar al usuario de forma segura sin posibilidad de conocer o recuperar el texto plano.	Hashing unidireccional con salting (bcrypt / Argon2)	Se exige irreversibilidad estricta para evitar la filtración de credenciales en caso de compromiso de la BD.	Implementar función de hash segura (bcrypt o Argon2) durante el registro y la validación en el inicio de sesión.	Hash almacenado en la tabla de usuarios y prueba de autenticación exitosa sin guardar la contraseña plana.
Cliente registrado	Dirección de despacho	direccion_despacho, comuna, region	Recuperar la ubicación física del cliente para procesar la logística y envío de los pedidos.	Cifrado simétrico en reposo (AES-256)	Reversibilidad obligatoria para la emisión de etiquetas de despacho por servicios de logística.	Aplicar cifrado AES-256 en la capa de persistencia /ORM gestionando la llave en un KMS externo.	BD mostrando el campo en texto cifrado y vista de gestión de despacho con el dato descifrado correctamente.
Cliente registrado	Dirección de facturación	direccion_facturacion, rut_facturacion	Emitir documentos tributarios legibles (boletas o facturas) requeridos legalmente.	Cifrado simétrico en reposo (AES-256)	Reversibilidad indispensable para generar comprobantes tributarios oficiales.	Cifrado de datos sensibles en la tabla de facturación con descifrado bajo demanda en el servicio de facturación.	Registro cifrado en BD y prueba de generación de factura en PDF descifrada.

Actividad N°2 – Del caso a los primeros riesgos
Caso elegido: Caso 1 – Plataforma de comercio electrónico: NortiShop - Tabla por Campo Sensible

Cliente registrado	Método de pago guardado	token_pago, mascara_tarjeta	Permitir compras recurrentes sin almacenar directamente datos sensibles de tarjetas bancarias (PAN).	Tokenización vía Vault / Pasarela de pagos	Cumplimiento normativo PCI-DSS al evitar almacenar números de tarjeta en la BD propia.	Integración con el SDK de la pasarela (ej. Transbank/ Stripe) que retorna un token reutilizable y seguro.	Almacenamiento exclusivo del token en BD y comprobante de transacción aprobada usando dicho token.
Cliente registrado	Historial de pedidos	id_pedido, fecha, monto_total, items	Consultar transacciones pasadas tanto por el cliente como por el sistema de gestión.	Cifrado simétrico de datos sensibles / Control de Acceso (RBAC) + TLS	Garantizar la privacidad del historial de compras e integridad de la información comercial.	Restringir el acceso mediante políticas RBAC y cifrar datos específicos de la orden en reposo.	Consulta exitosa por el cliente autenticado y bloqueo de acceso no autorizado en la API.
Cliente registrado	Saldo de NortiPuntos	saldo_puntos, historial_puntos	Consultar y redimir puntos del programa de fidelización durante el flujo de compra.	Control de Integridad (Hash HMAC / SHA-256) + TLS	Prevenir la alteración maliciosa o manipulación no autorizada del saldo disponible.	Firma del saldo utilizando un código HMAC en servidor para verificar la integridad antes de redimir.	Verificación de firma HMAC al actualizar/redimir puntos y saldo visible en el panel.
Cliente registrado	Reseñas de productos	comentario_resena, calificacion, id_producto	Publicar comentarios y valoraciones visibles públicamente en el catálogo.	Seudonimización / Control de Acceso (Dato público)	Dato de carácter público; requiere sanitización para prevenir vulnerabilidades (XSS).	Sanitización de entradas web y vinculación mediante un identificador seudonimizado de cliente.	Reseña visible en la ficha del producto mostrando solo el alias del usuario.
Cliente registrado	Carrito de compras	id_carrito, productos, cantidades	Mantener los artículos seleccionados durante la navegación de la sesión activa.	Cifrado en tránsito (TLS) / Cookies de sesión seguras	Persistencia temporal del estado de compra asegurando el canal de comunicación.	Configuración de cookies con atributos Secure y HttpOnly o sesión en almacenamiento en caché seguro (Redis).	Inspección de cabeceras de red con flag Secure y mantenimiento de carrito entre páginas.

Actividad N°2 – Del caso a los primeros riesgos
Caso elegido: Caso 1 – Plataforma de comercio electrónico: NortiShop - Tabla por Campo Sensible

Cliente registrado	Estado del pedido	estado_envio, codigo_seguimiento	Informar al cliente sobre la etapa actual del despacho de sus productos.	Cifrado en tránsito (TLS/HTTPS) + Control de Acceso	Transmisión segura para evitar el rastreo o interceptación por parte de terceros.	Exposición del estado mediante API REST protegida por JWT transmitida obligatoriamente sobre HTTPS.	Captura de solicitud HTTPS con respuesta JSON autorizada y visualizada en la interfaz.
Cliente invitado	Nombre y datos de contacto	nombre_invitado, email_invitado, telefono_invitado	Contactar al comprador no registrado para enviar confirmaciones y notificaciones de entrega.	Cifrado simétrico en reposo (AES-256) + TLS en tránsito	Reversibilidad necesaria durante la vida útil del pedido con política de retención limitada.	Cifrado en reposo en la tabla de ventas a invitados con clave resguardada fuera del repositorio.	Envío exitoso de email de confirmación y dato cifrado en la base de datos.
Cliente invitado	Dirección de despacho	direccion_envio_invitado	Entregar los productos adquiridos por el usuario invitado en su domicilio.	Cifrado simétrico en reposo (AES-256)	Reversibilidad obligatoria para ser procesada por el operador logístico.	Cifrado del campo de dirección en la orden efímera de invitado.	Etiqueta de envío generada con la dirección descifrada y dato protegiéndose en la BD.
Cliente invitado	Datos ingresados en el checkout	datos_checkout_temporal	Procesar el pago inmediato y confirmar la orden de compra de forma rápida.	Cifrado en tránsito (TLS / HTTPS) + Tokenización de pago	Protección de datos sensibles en tránsito sin almacenarlos de forma permanente en la BD.	Uso obligatorio de TLS 1.3 en el formulario de pago y envío directo de tarjetas a la pasarela.	Certificado SSL/TLS válido verificado en el navegador durante el checkout.
Cliente invitado	Información del pedido	id_orden_invitado, resumen_compra	Permitir al cliente invitado consultar el estado de su orden mediante un enlace seguro.	Token de acceso único (UUID v4) + HTTPS	Acceso restringido mediante identificador no predecible en lugar de autenticación con clave.	Generación de token UUID v4 en la URL de seguimiento enviada por correo electrónico sobre HTTPS.	Acceso correcto al resumen del pedido mediante la URL con token único en HTTPS.
Administrador de la tienda	Información de pedidos	panel_pedidos_admin	Gestionar el estado de las órdenes, cancelaciones, despachos y devoluciones de la tienda.	Control de Acceso Basado en Roles (RBAC) + Cifrado en tránsito (TLS)	Garantizar el principio de menor privilegio y trazabilidad de las acciones sobre las órdenes.	Implementación de middleware RBAC en el panel administrativo con registros de auditoría (audit logs).	Registros de logs donde se audita el acceso del administrador a la información de pedidos.

Actividad N°2 – Del caso a los primeros riesgos
Caso elegido: Caso 1 – Plataforma de comercio electrónico: NortiShop - Tabla por Campo Sensible

Administrador de la tienda	Precios y datos del catálogo	precio, stock, descripcion_producto	Actualizar la oferta de productos, precios y disponibilidad en el sitio web.	Control de Integridad (Hash SHA-256 / Audit Logs) + RBAC	Los datos son públicos, pero se debe prevenir la modificación no autorizada o fraudulenta.	Restricción de edición por rol de Administrador de Catálogo y firma de cambios en el log del sistema.	Producto publicado correctamente con registro del usuario administrativo que realizó el cambio.
Administrador de la tienda	Datos de clientes	listado_clientes_pii	Brindar soporte técnico, gestionar reclamos y resolver incidencias de clientes.	Cifrado simétrico (AES-256) + RBAC + Desenmascaramiento bajo demanda	Acceso limitado estricto a PII únicamente cuando exista una solicitud de soporte justificada.	Función de descifrado restringida a nivel de servicio que enmascara por defecto (ej. j***@email.com).	Visualización enmascarada por defecto y log de auditoría registrado al revelar la PII completa.
Pasarela de pago externa	Datos de la transacción	monto, id_transaccion, codigo_autorizacion	Validar y ejecutar el cobro financiero de la compra realizada.	Cifrado en tránsito (TLS/HTTPS) + Firma digital (HMAC)	Asegurar la confidencialidad, autenticidad e no repudio de la transacción financiera.	Envío de payload firmado con llave secreta compartida a través de la API HTTPS de la pasarela.	Verificación exitosa de la firma HMAC en la respuesta enviada por la pasarela.
Pasarela de pago externa	Estado del pago	status_pago	Actualizar de manera automática e instantánea el estado de la orden mediante Webhook.	Cifrado en tránsito (TLS) + Validación de Firma de Webhook (HMAC)	Prevenir ataques de suplantación o falsificación de notificaciones de pago.	Validación obligatoria de la firma digital incluida en los headers del webhook enviado por la pasarela.	Log del sistema confirmando la firma válida del webhook antes de cambiar el estado a Pagado.
Pasarela de pago externa	Servicio de pago	endpoint_api_pasarela	Intercambiar mensajes e instrucciones de cobro entre el servidor web y la pasarela.	Cifrado Asimétrico / TLS + Autenticación por API Key	Garantizar canal seguro y autenticación mutua de los sistemas en comunicación.	Configurar solicitudes HTTP cliente con TLS 1.3 autenticadas mediante API Key en variables de entorno.	Solicitud API con respuesta status 200 OK y canal seguro TLS verificado.

Actividad N°2 – Del caso a los primeros riesgos
Caso elegido: Caso 1 – Plataforma de comercio electrónico: NortiShop - Tabla por Campo Sensible

Equipo de marketing	Correo electrónico del cliente	email_suscripcion, nombre_contacto	Enviar campañas promocionales, boletines e información publicitaria autorizada.	Seudonimización / Cifrado en reposo (AES-256) + TLS en tránsito	Cumplimiento de normativas de privacidad (Ley 21.719 / GDPR) y gestión de consentimiento (Opt-in).	Sincronización segura mediante API HTTPS hacia la plataforma de Email Marketing con token de desuscripción.	Registro de consentimiento explícito del cliente y enlace funcional de desuscripción cifrado.